



DNS安全

李琦

清華大學網研院



本章的內容組織



第一節 DNS概述

- DNS的演進
- DNS域名結構及區域組織形式



第二節 DNS使用及解析過程

- DNS使用
- DNS解析過程

熟悉DNS
運行原理

思考DNS
安全問題

DNS在設計之初
缺乏安全考慮



第三節 DNS攻擊

- 緩存中毒攻擊
- 惡意DNS服務器回復偽造
- 拒絕服務攻擊

掌握DNS
攻擊技術

瞭解DNS
防禦策略

多種攻擊技術
需要特定的防禦
策略進行防護



第四節 DNS攻擊預防策略

- 基于密碼技術
- 基于系統管理
- 新型架構設計

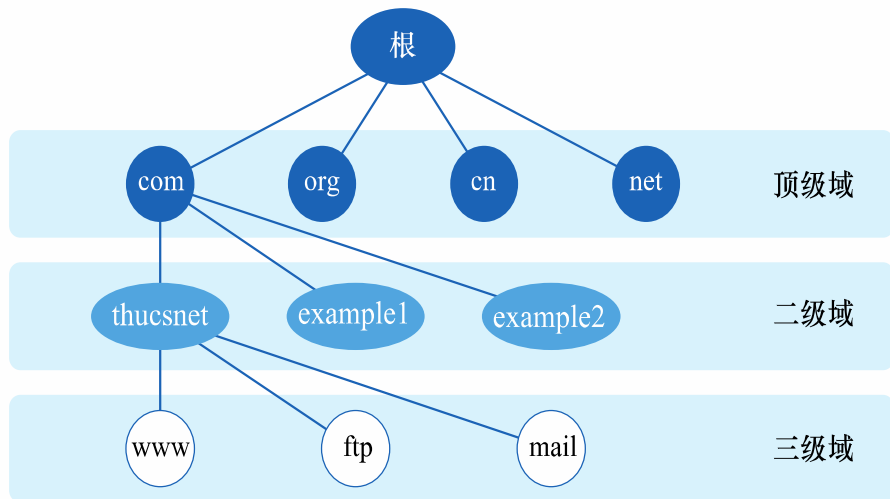


第一節 DNS概述

- ✓ DNS的演進
- ✓ DNS域名結構與區域組織形式



DNS域名結構

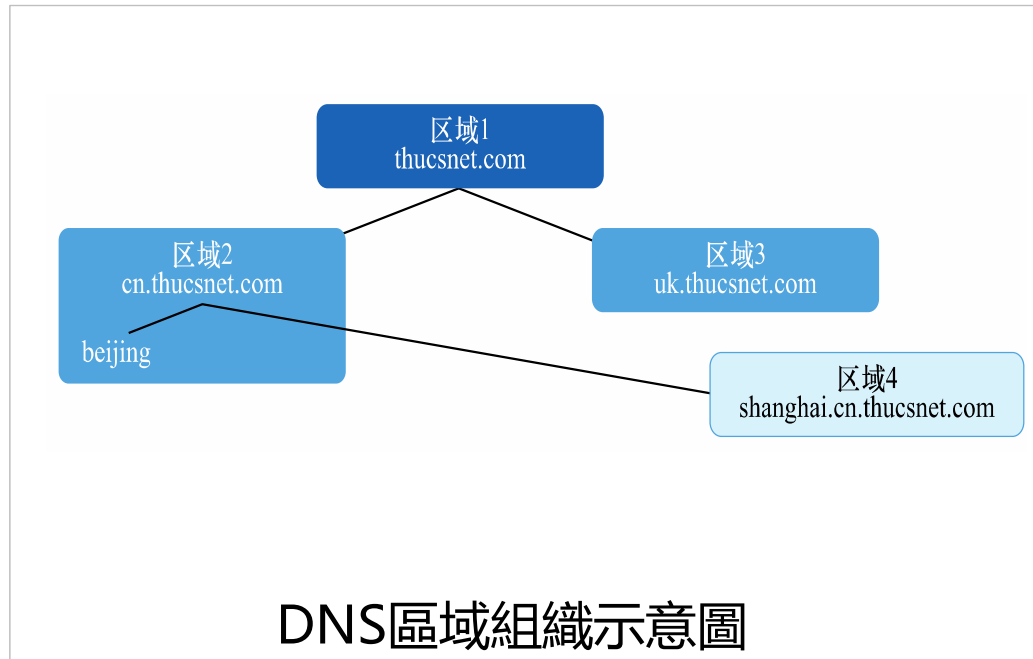


域名空間層次化授權結構

- 域名系統採用層次化樹形結構
- 樹形最頂層為根（Root），進一步劃分頂級域（TLD），頂級域管理機構授權給二級域名（SLD）
- 層次化授權行為最多可迭代127 次



DNS區域組織形式



thucsnet.com分配
cn.thucsnet.com,
uk.thucsnet.com兩個子域,
cn.thucsnet.com包含兩個區域

每個DNS區域至少有一個**權威
域名服務器**發布關於這個區域
的信息

- 一個域名沒有被分割成子域或包含了子域全部數據，則域名和區域相同
- 一個域名被分割成子域，每個子域有自己的區域時，域名和區域具有不同的意義



DNS區域組織形式



權威域名服務器

- 每個DNS區域的**權威域名服務器**，發布關於該區域的信息，并響應DNS查詢請求
- **權威域名服務器**可以配置主從服務器，主服務器存儲所有區域記錄的記錄，而從服務器使用自動更新機制維護主記錄的副本





DNS區域組織形式



DNS根服務器 (ROOT)

List of Root Servers

HOSTNAME	IP ADDRESSES	MANAGER
a.root-servers.net	198.41.0.4, 2001:503:ba3e::2:30	VeriSign, Inc.
b.root-servers.net	199.9.14.201, 2001:500:200::b	University of Southern California (ISI)
c.root-servers.net	192.33.4.12, 2001:500:2::c	Cogent Communications
d.root-servers.net	199.7.91.13, 2001:500:2d::d	University of Maryland
e.root-servers.net	192.203.230.10, 2001:500:a8::e	NASA (Ames Research Center)
f.root-servers.net	192.5.5.241, 2001:500:2f::f	Internet Systems Consortium, Inc.
g.root-servers.net	192.112.36.4, 2001:500:12::d0d	US Department of Defense (NIC)
h.root-servers.net	198.97.190.53, 2001:500:1::53	US Army (Research Lab)
i.root-servers.net	192.36.148.17, 2001:7fe::53	Netnod
j.root-servers.net	192.58.128.30, 2001:503:c27::2:30	VeriSign, Inc.
k.root-servers.net	193.0.14.129, 2001:7fd::1	RIPE NCC
l.root-servers.net	199.7.83.42, 2001:500:9f::42	ICANN
m.root-servers.net	202.12.27.33, 2001:dc3::35	WIDE Project



根服務器管理互聯網主目錄，13台IPv4（名爲“A”至“M”），1個主根服務器由美國VeriSign公司運營，12個輔根服務器，9個由美國運營，英國和瑞典、日本各1個，每個根服務器通過anycast方式在多個國家和地區部署



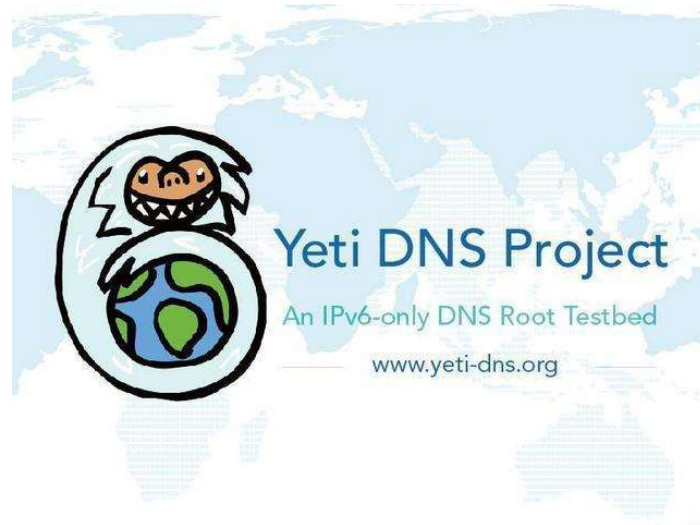
DNS區域組織形式

“雪人計劃”

- 2015年6月，我國下一代互聯網工程中心領銜發布運營IPv6根服務器的“雪人計劃”
- 2016年在美國、日本等16個國家架設25台IPv6根服務器，形成13台原有根加25台IPv6根（3台主根）的新格局。中國部署其中4台（1台主根和3台輔根服務器）

“雪人计划” IPv6根服务器全球分布情况

国家	主根服务器	辅根服务器	国家	主根服务器	辅根服务器
中国	1	3	西班牙	0	1
美国	1	2	奥地利	0	1
日本	1	0	智利	0	1
印度	0	3	南非	0	1
法国	0	3	澳大利亚	0	1
德国	0	2	瑞士	0	1
俄罗斯	0	1	荷兰	0	1
意大利	0	1			



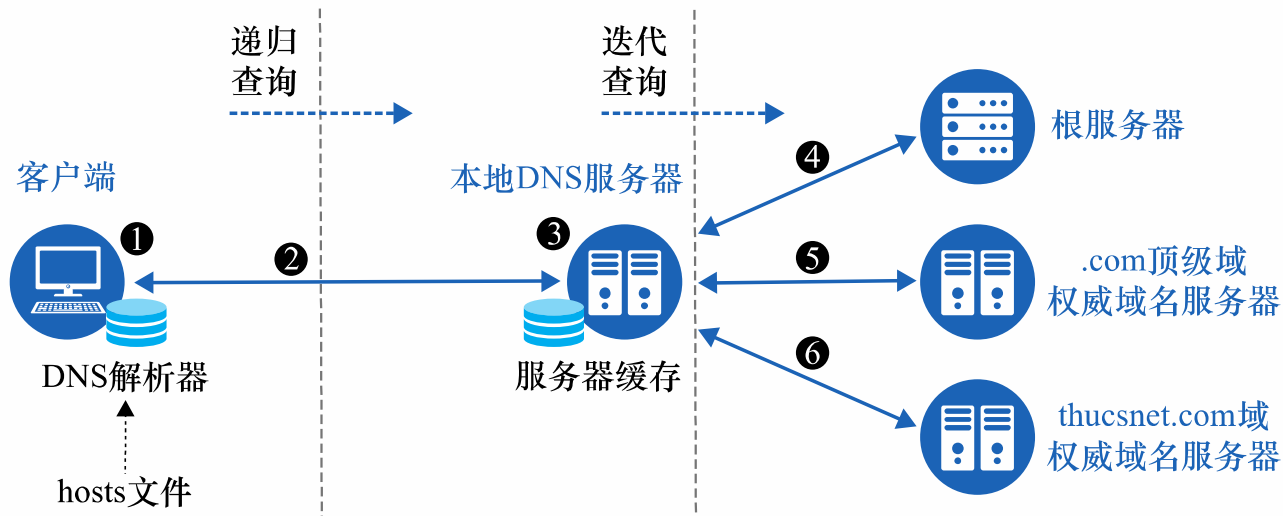


第二節 DNS使用及解析過程

- ✓ DNS使用
- ✓ DNS解析過程



DNS請求過程



1. 客户端：查詢本機緩存及hosts文件
2. 向本地DNS服務器發送請求
3. 本地DNS查找緩存，有結果就返回
- 4-6. 本地DNS查找根服務器、.com頂級域、thucsnet.com域，獲取結果
7. 本機獲取IP地址

并不是每一次域名解析都完成整個查詢流程



DNS迭代查詢過程交互信息格式

常見資源記錄類型及其含義

資源記錄類型	含義
A	域名對應主機的IPv4地址
AAAA	域名對應主機的IPv6地址
MX	域名對應郵件服務器地址
NS	域名對應權威服務器名稱
CNAME	域名指向的別名記錄

- 域名解析應答，每個數據條目稱為一個資源記錄（Resource Record, RR）
- 資源記錄的數據格式為標準五元組：域名、類別、類型、生存時間（TTL）與數據



DNS迭代查詢過程交互信息格式

DNS應答包括問題、回復、授權和附加部分



問題區 (Question Section)

查詢內容，如www.thucsnet.com. IN A表示查www.baidu.com的A記錄



應答區 (Answer Section)

A/ CNAME/ NS等記錄查詢的答案



授權區 (Authority Section)

通知本地DNS服務器問誰會更接近答案



附加區 (Additional Section)

存放附加記錄，如給出權威NS記錄相應的A記錄



DNS迭代查詢過程交互信息格式

dig: DNS information Groper

發送 “dig @a.root-servers.net www.thucsnet.com” 命令，根服務器在授權部分提供.com區域權威域名服務器，對應地址在附加部分

:: QUESTION SECTION:

thucsnet.com.	IN	A
---------------	----	---

:: AUTHORITY SECTION:

com.	172800	IN	NS	h.gtld-servers.net.
com.	172800	IN	NS	d.gtld-servers.net.
com.	172800	IN	NS	f.gtld-servers.net.
com.	172800	IN	NS	b.gtld-servers.net.

:: ADDITIONAL SECTION:

h.gtld-servers.net.	172800	IN	A	192.54.112.30
d.gtld-servers.net.	172800	IN	A	192.31.80.30
f.gtld-servers.net.	172800	IN	A	192.35.51.30
b.gtld-servers.net.	172800	IN	A	192.33.14.30



DNS迭代查詢過程交互信息格式

本地DNS服務器通過 “dig @f.gtld-servers.net www.thucsnet.com”
得到thucsnet.com區域的權威域名服務器及地址

:: AUTHORITY SECTION:

thucsnet.com.	172800	IN	NS	dns2.hichina.com.
thucsnet.com.	172800	IN	NS	dns1.hichina.com.

:: ADDITIONAL SECTION:

dns2.hichina.com.	172800	IN	A	106.11.141.114
dns2.hichina.com.	172800	IN	AAAA	2400:3200:2000:21::1
dns1.hichina.com.	172800	IN	A	106.11.141.113



DNS迭代查詢過程交互信息格式

本地DNS服務器通過 “dig @dns1.hichina.com www.thucsnet.com”
得到IP地址

```
:: QUESTION SECTION:
;www.thucsnet.com.          IN      A

:: ANSWER SECTION:
www.thucsnet.com.  600     IN      A      47.94.221.113
```



DNS反向查詢

- 使用dig -x IP, DNS解析器通過迭代查詢發送請求, 使用IP地址獲得相關域名或主機名
- 如對地址8.8.8.8發起查詢, 則ANSWER SECTION得到地址對應的域名

```
$ dig -x 8.8.8.8

;; QUESTION SECTION:
;8.8.8.8.in-addr.arpa.      IN      PTR

;; ANSWER SECTION:
8.8.8.8.in-addr.arpa.      5       IN      PTR      dns.google.
```



第三節 DNS攻擊

- ✓ 緩存中毒攻擊
- ✓ 惡意DNS服務器回復偽造
- ✓ 拒絕服務攻擊



DNS攻擊面





操控本地用戶主機

修改/etc/resolv.conf

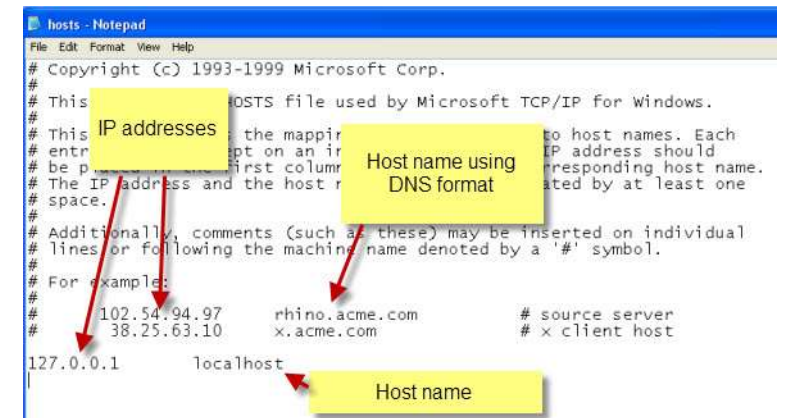
將主機DNS服務器修改成攻擊者控制的服務器，攻擊者回復惡意內容

修改/etc/hosts

直接修改地址與域名映射關係，如將“www.taobao.com”修改為攻擊者控制的IP地址

嗅探回復

監聽主機發出的DNS查詢請求，注入惡意回復



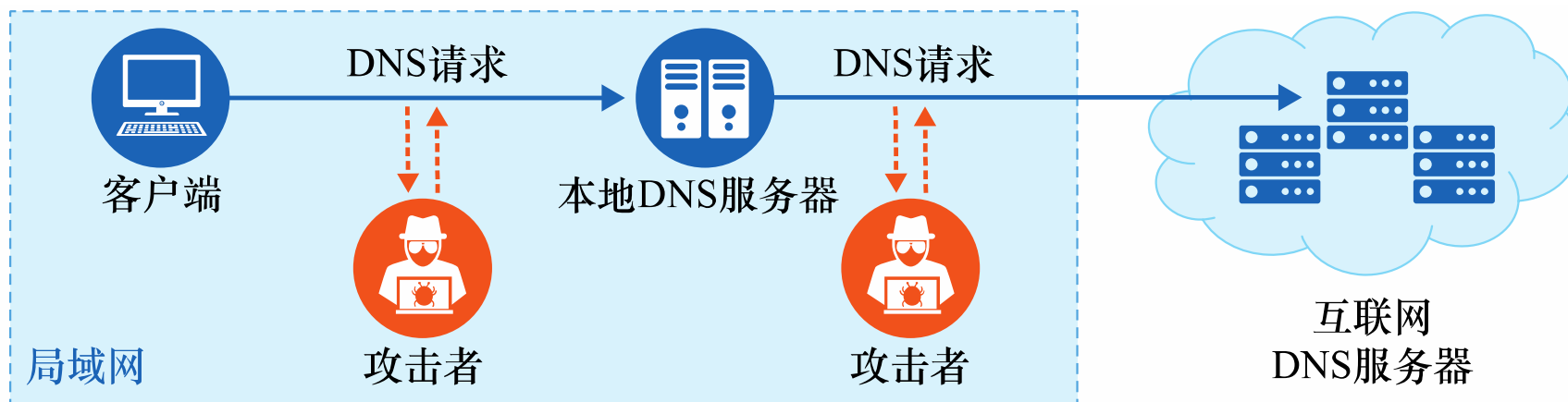
攻擊面小
收益低

距離限制
難度大



本地緩存中毒攻擊

- 偽造DNS回復，攻擊者需要知道請求中的一些參數，如UDP源端口號、請求事務ID、請求問題等
- 由于UDP包沒有加密，攻擊者可以在局域網直接捕獲并解析請求



本地DNS緩存中毒示意圖

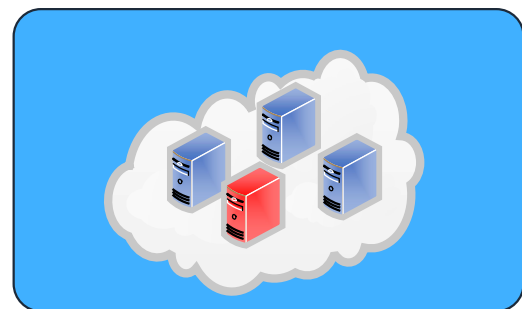


本地緩存中毒攻擊



只針對回復部分偽造，影響面：一個主機名

在偽造回復中，把主機名映射到攻擊地址，告訴本地DNS服務器域名對應地址是攻擊者的計算機



針對授權部分攻擊，影響面：整個域

將ns.attack.com放在授權部分，查詢目標域內任何一個主機名時，本地DNS服務器把請求發給ns.attack.com



本地緩存中毒攻擊

由于能够嗅探到請求數據包，無需猜測端口號等信息，可采用scapy組裝偽造數據包

```
; <<>> DiG 9.10.3-P4-Ubuntu <<>> www.example.org
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 1367
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0,
ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 4096
;; QUESTION SECTION:
; www.example.org.                IN      A

;; ANSWER SECTION:
www.example.org.                172800  IN      A      108.109.10.66

;; Query time: 19 msec
;; SERVER: 10.0.10.5#53(10.0.10.5)
;; WHEN: Fri Jan 22 12:27:52 EST 2021
```

← 查詢用戶從本地DNS
服務器得到惡意回復



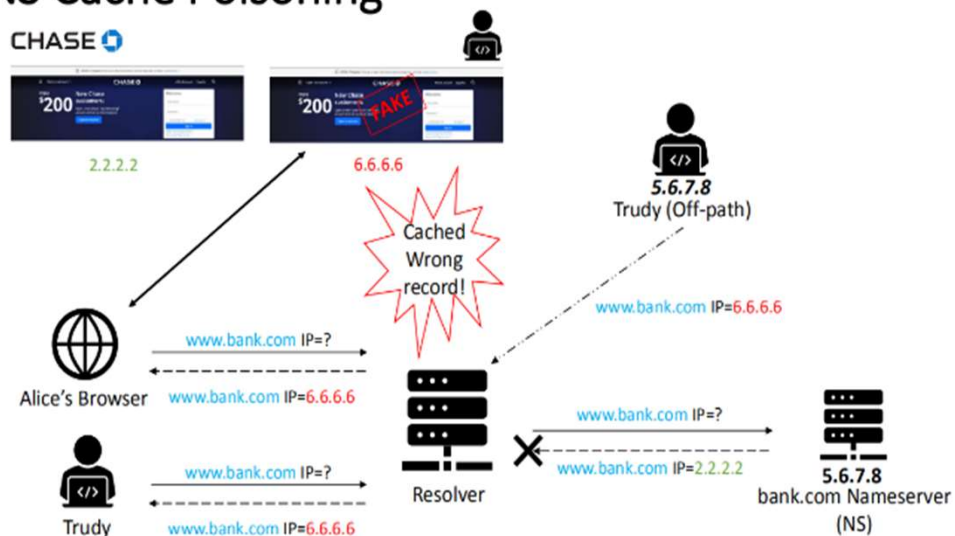
遠程緩存中毒攻擊：Kaminsky攻擊

2008年7月，Dan Kaminsky精心構造了緩存投毒攻擊，有專家認為這可能是互聯網歷史上最大的一次DNS安全事件



一次出人意料而名留青史的DNS投毒攻擊

DNS Cache Poisoning



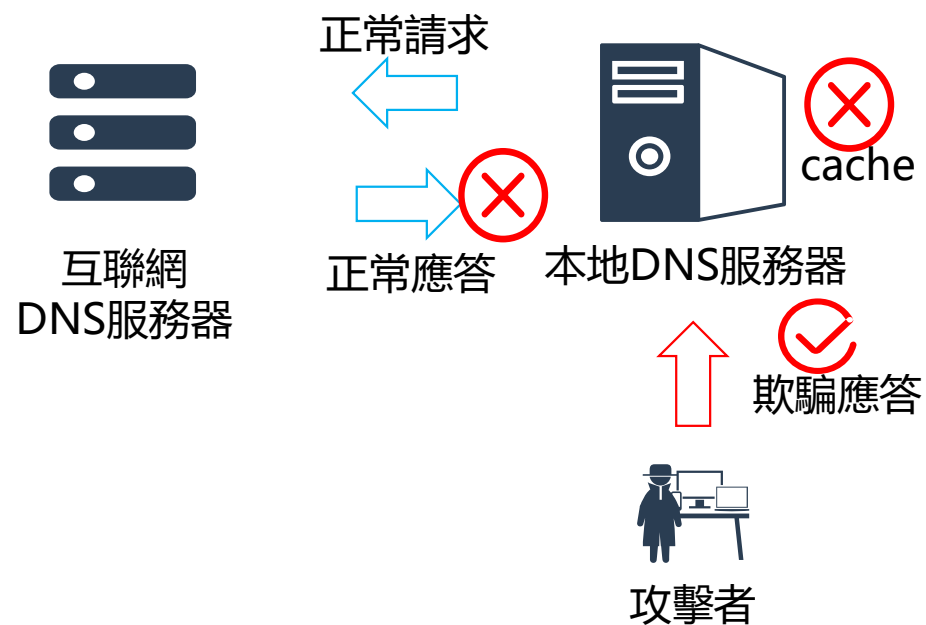


遠程緩存中毒攻擊

如何偽造一個被受害者接收的應答包？

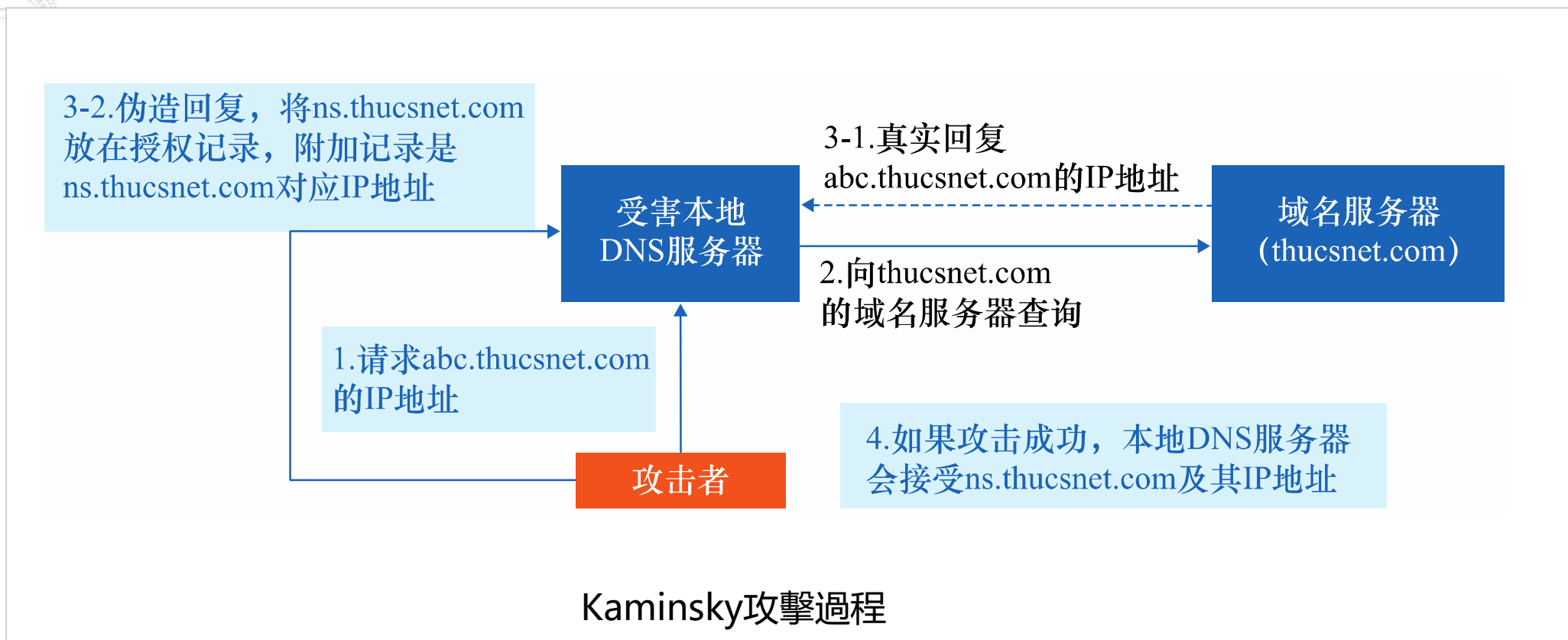
接受欺騙應答面臨的**約束**

- 01 緩存時限約束
域名不能在緩存中，**這是個難點**
(域名緩存時間長達一天)
- 02 應答包匹配約束
端口號、事務ID匹配
- 03 時間約束
偽造包比正常DNS應答快





遠程緩存中毒攻擊—持續發起不存在的域名請求



關鍵點： 主動訪問不存在的域名，這種域名在本地DNS服務器沒有緩存



遠程緩存中毒攻擊

成功原因：

在權威區和附加區實施欺騙

問題區：abc.example.com A

應答區：（空）

權威區：example.com NS www.example.com

附加區：www.example.com A 1.2.3.4

偽造包並沒有包含abc.example.com的A記錄，但告訴LDNS可以去www.example.com查詢，並且www.example.com對應的IP是1.2.3.4

去
1.2.3.4
查詢

解決方案：

源端口隨機化，域名大小寫增加攻擊者猜測難度等



遠程緩存中毒攻擊—構建回復包頭



DNS回復包頭格式

- 回復包有5個字段必須必須與請求包匹配，包括源IP地址、目的IP地址、**源端口號**、目的端口號、**事務ID**
- 如所攻擊的域有**多個域名服務器**，則隨機選擇一個服務器發送回復包，或同時發送多個回復包



遠程緩存中毒攻擊—包頭參數猜測



請求包源IP地址

DNS服務器地址

請求包目的端口號

DNS 端口號, 53

已知

請求包的目的IP地址

權威域名服務器 (可能有多個)

請求包的源端口號

16bit, 隨機猜測

事務ID

16bit, 隨機猜測

未知

難點：遠程攻擊者猜測準確的概率為 $1/2^{32}$ ，成功概率極低



遠程緩存中毒攻擊—構建回復包負載

問題記錄

名字	記錄類型	DNS類
abc.example.com	"A" Record 0x0001	Internet 0x0001

回復記錄

名字	記錄類型	DNS類	存活時間	數據長度	數據: IP地址
abc.example.com	"A" Record 0x0001	Internet 0x0001	0x00001 000	0x0004	1.2.3.4

授權記錄

名字	記錄類型	DNS類	存活時間	數據長度	數據: 域名服務器
abc.example.com	"NS" Record 0x0002	Internet 0x0001	0x00001 000	0x0011	ns.attacker.com

DNS回復負載格式

- 問題記錄和回復記錄的名字應該與請求包相匹配，否則記錄不會被接受
- 授權記錄，域名必須和回復記錄中的域名相關聯，否則授權記錄會被忽略



遠程緩存中毒攻擊——側信道攻擊

利用數據包分片重組技術注入虛假分片

利用 UDP 數據包分片重組技術，攻擊者提前向遞歸解析服務器注入虛假 DNS 響應分片，利用數據包重組過程篡改重組後的域名解析結果，實現緩存中毒攻擊

Offsets	Octet	0																1								2								3								
Octet	Bit	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31									
0	0	v4				IHL = 20				TOS				Total Length = 85																Header Section Section												
4	32					IPID = 23456								x DF MF				Frag Offset = 48																								
8	64	TTL				Protocol = 17				IP Header Checksum																																
12	96	Source IP = 2.2.2.2																Destination IP = 7.7.7.7																								
16	128	Data Length = 4																IPv4 Address																								
20	160																																									
24	192	= 2.2.2.2																Name = 0																								
28	224	= OPT																Type																								
32	256	Version = 0																EXTENDED-RCODE = 0																								
36	288	= 0																Data Length																								

Fig. 1 ICMP fragmentation needed packet from attacker at 6.6.6.6 to nameserver at 2.2.2.2 indicating an MTU of 100 bytes for resolver at 7.7.7.7

Offsets	Octet	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
Octet	Bit	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
0	0	v4				IHL = 20				TOS				Total Length = 85																			
4	32					IPID = 23456								x DF MF				Frag Offset = 0															
8	64	TTL								Protocol = 17				IP Header Checksum																			
12	96	Source IP = 2.2.2.2																															
16	128	Destination IP = 7.7.7.7																															
20	160	Source Port = 53																Destination Port = 12345															
24	192	Length = 65																UDP Checksum = 0x14de															
28	224	TXID = 76543																QR Opcode = 0 AA TC RD RA Z RCODE = 0															
32	256	Question Count = 1																Answer Record Count = 1															
36	288	Authority Record Count = 0																Additional Record Count = 1															
40	320	4				m								a								i											
44	352	l				4								v								i											
48	384	c				t								2								i											
52	416	m								0				Type = A																			
56	448	Class = IN																Name (Pointer)															
60	480	Type = A																Class = IN															
64	512	TTL																															

UDP Header

DNS Header

Question

Answer

Fig. 2 First fragment sent by the nameserver at 2.2.2.2 to the DNS resolver at 7.7.7.7, assuming MTU of 68 bytes



遠程緩存中毒攻擊—基于IPID的攻擊

攻擊成功的前提是受害者接受該IPID，即偽造的第二個分片與真實的第一個分片具有相同IPID值，攻擊者可以采取不同的操作實現

Sequentially Incrementing

攻擊者從域名服務器中採樣IPID值及增長速率，然後計算可能的IPID

>60%

Per-Destination

對每個目的地遞增的IPID，攻擊者采用算法預測可能的IPID

<40%

Random

發送多個分片按概率命中，目前Windows版本支持100個，Linux版本64個分片

少量



遠程緩存中毒攻擊—基于交易ID的攻擊

利用端口掃描先得到源端口號，再猜測交易ID

通過側信道實現UDP端口掃描，將需要猜測的32位空間（ $1/2^{32}$ ）進一步降低至16位（ $1/2^{16}$ ），能够在幾分鐘內成功實現攻擊

Figure 7: DNS Response Used to Overwrite Cache

Field	Value
Question	{nonce}.www.victim.com
Answer	
Authoritative	www.victim.com NS ns.attacker.com
Additional	

Table 3: Production Resolver Attack Results

Exp.	RTT range	Probe loss	Name sever mute level	Average time taken	Success rate
Base(D)	0.2-1.2ms	~0%	80%	504s	20/20*
Base(M)	0.2-1.2ms	~0%	80%	410s	20/20*
Mute Lv.	0.2-1.2ms	~0%	75%	1341s	18/20*
Mute Lv.	0.2-1.2ms	~0%	66.7%	2196s	20/20#
Mute Lv.	0.2-1.2ms	~0%	50%	8985s	9/20#
Altered	37-43ms	0.20%	80%	930s	5/5*

*: 1-hour threshold. #: 3-hour threshold. D: Day. M: Midnight

*: 1-hour threshold. #: 3-hour threshold. D: Day. M: Midnight

Exp.	RTT range	Probe loss	Name sever mute level	Average time taken	Success rate
Base(D)	0.2-1.2ms	~0%	80%	504s	20/20*
Base(M)	0.2-1.2ms	~0%	80%	410s	20/20*
Mute Lv.	0.2-1.2ms	~0%	75%	1341s	18/20*
Mute Lv.	0.2-1.2ms	~0%	66.7%	2196s	20/20#
Mute Lv.	0.2-1.2ms	~0%	50%	8985s	9/20#
Altered	37-43ms	0.20%	80%	930s	5/5*



拒絕服務攻擊

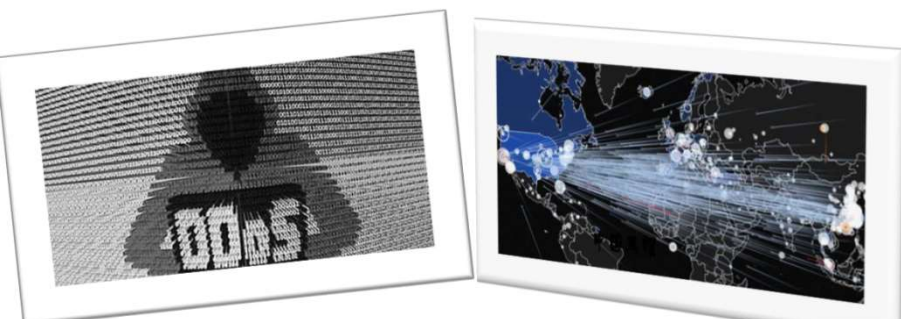
拒絕服務

對root和TLD服務器的拒絕服務攻擊

如果攻擊者可以成功攻破root區域的服務器，則整個互聯網將會崩潰。但是由于root域名服務器基礎設施采用分布式部署方式，很難被全部攻破

對特定域名服務器的拒絕服務攻擊

2019年亞馬遜的雲計算部門AWS遭受了持續了大約八小時的DDoS攻擊，AWS通過Shield Advanced提供了緩解措施，但無法完全阻止攻擊





攻擊根服務器—難以成功

DNS根服務器技術：IP Anycast + BGP

通過BGP在多個不同地點同時廣播一個IP地址，BGP路由器從中選擇（最近）一個作為路由

Threat Mitigation for the Root Server System

Root Server Operators
August 2019

Introduction





攻擊頂級服務器—巨大威脅

2013年8月25日凌晨，.CN域名凌晨出現大範圍解析故障，導致大面積.CN域名無法解析，直到當日凌晨4點左右，CN根域名服務器解析才開始部分恢復

DDoS攻击背后的利益链条

大家可能会有疑问，看似普通的DDoS攻击其背后究竟隐藏着什么？一句话：为了利益。本次事故中攻击者使用的手法(譬如攻击一些“私服”的网站或主机)并不罕见，且近些年有愈演愈烈的趋势。自国内的互联网事业兴起以来，国内有一些常年进行DDoS攻击的组织或个人，胁迫某些“私服”游戏的运营团队并收取“保护费”，如果不合作便采取DDoS暴力攻击，使其无法正常运营。而这



中国遭到的DDoS攻击表明 TLD服务器也不安全

2013年08月28日 15:59:49 | 作者：胡杨编译 | 来源：网界网 | 查看本文手机版



本文手机版

摘要：上周末发生的让中国的部分互联网断网的DDoS攻击表明，全球各国域名的互联网实力有很大区别。

标签 顶级域名 CNIC TLD服务器 DDoS攻击

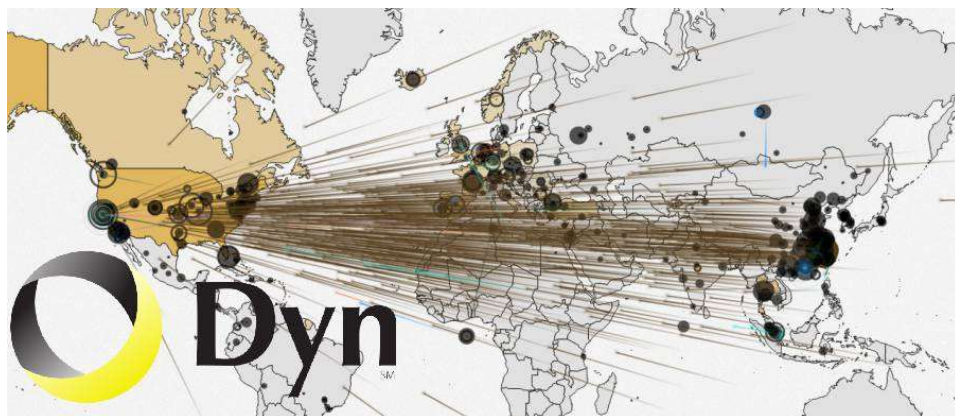
【CHW.com.cn独家译稿】上周末发生的让中国的部分互联网断网的DDoS攻击表明，全球各国域名的互联网实力有很大区别。

运行中国“.cn”顶级域名的服务器在美国东部时间星期日早上2点遭到了攻击。运行这个顶级域名的中国互联网信息中心(CNIC)证实了这次攻击，并且向受到影响的用户道歉。



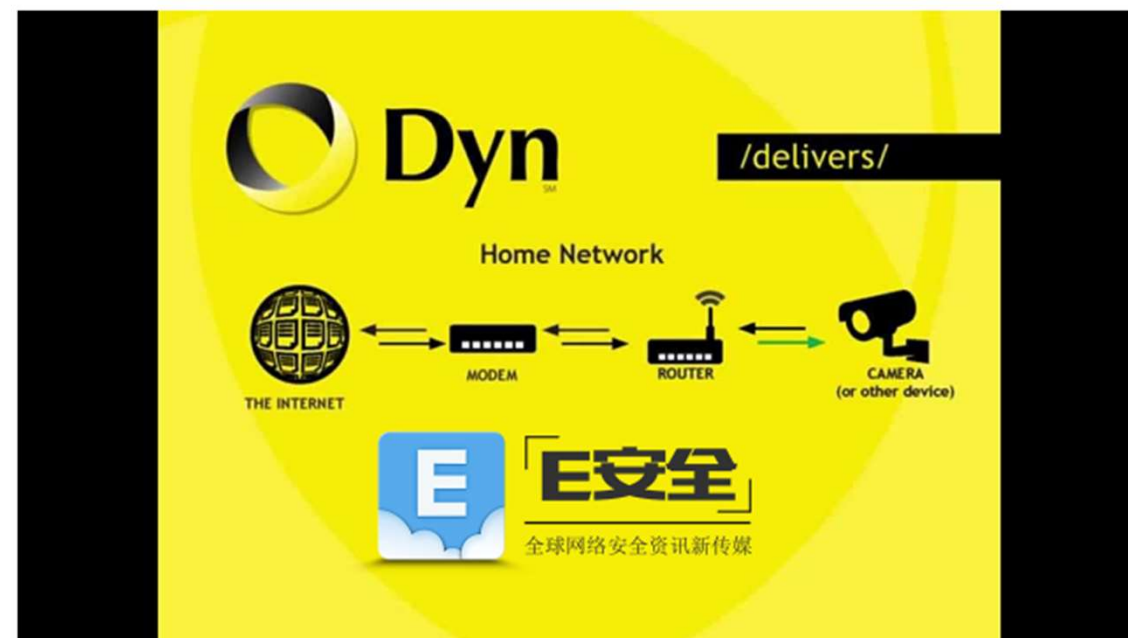
攻擊特定域名服務器—影響深遠

2016年，攻擊者控制大量物聯網設備發起DDoS攻擊，造成CNN,BBC,PayPal等網站無法訪問



美国Dyn公司声明：关于2016年10月21日的DDoS攻击

2016-10-23 19:06





DNS安全問題的原因及特徵

DNS安全問題的本質原因?

- 1.客觀上協議設計的不完備，緩存等面向性能優化的設計帶來了安全風險
- 2.主觀上基于利益驅動，攻擊者不斷挖掘漏洞

DNS攻擊有哪些共有特徵?

- 1.針對明文傳輸和無身份認證的實體進行欺騙性攻擊
- 2.尋找并突破域名間複雜依賴關係，實現對域名服務器攻擊
- 3.針對防護措施不足的服務器發起拒絕服務攻擊



第四節 DNS攻擊預防策略

- ✓ 基于密碼技術
- ✓ 基于系統管理
- ✓ 新型架構設計



通過非對稱加密驗證身份--DNSSEC

DNSSEC引入公鑰加密/認證體系，通過簽名提供端到端數據真實性和完整性保護



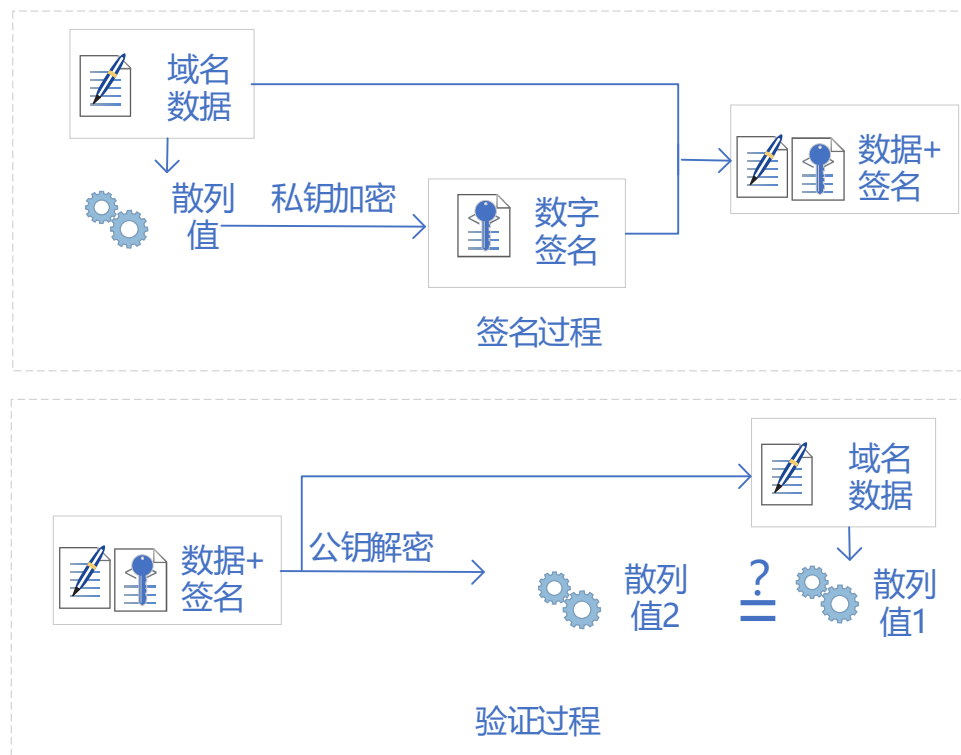
部署DNSSEC的權威域名服務器
對其區域文件中資源記錄用私鑰
(Zone signing key, ZSK) 進
行數字簽名



接收方用公鑰驗證簽名，判定
域名解析結果是否在傳輸過程
中被篡改



通過非對稱加密驗證身份--DNSSEC



DNS簽名及驗證過程示意圖

簽名過程原理

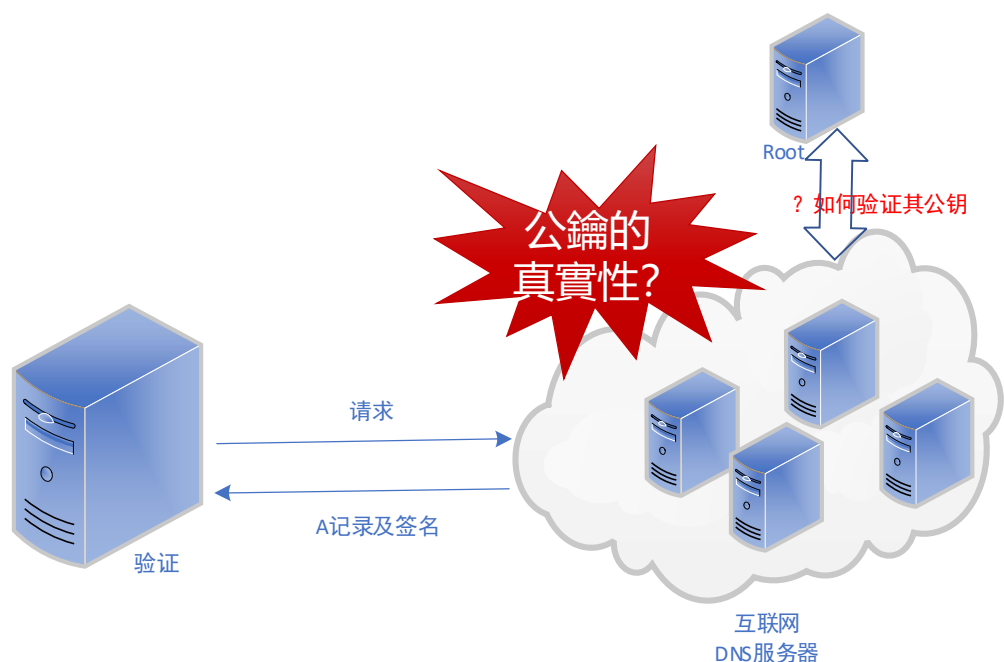
域名服務器用散列函數計算回復DNS報文內容的散列值，即“內容摘要”，使用私鑰對其加密（簽名），加密後的信息附加到DNS報文

驗證過程原理

本地DNS服務器收到DNSSEC報文，計算報文“內容摘要”，利用公鑰解密收到加密“摘要”，對比“摘要”內容



通過非對稱加密驗證身份—DNSSEC驗證公鑰



DNSSEC驗證需要公鑰信任鏈

- DNSSEC需要一條信任鏈：支持DNSSEC的本地DNS服務器向支持DNSSEC的權威服務器發起記錄請求，得到權威服務器數字簽名，簽名的正確性（公鑰）由上級服務器保證
- 假設DNSSEC 實現了全部署，每個遞歸服務器只需保留根域名服務器的DNSKEY



通過非對稱加密驗證身份--DNSSEC

RRSIG (Resource Record Signature)

Type covered: 該RRSIG涉及的DNS記錄類型

Algorithm: 生成最終簽名所用的加密算法

Label count: 原始RRSIG記錄名中的標籤數 (用于驗證通配符)

Original TTL: 所涉及記錄集的TTL值

Signature expiration: 簽名的過期時間

Signature inception: 最初創建簽名的時間

Key tag: 一個數值, 用于識別驗證該RRSIG簽名的DNSKEY記錄

Signer name: 用于驗證該簽名的DNSKEY記錄名稱

Signature: 用于驗證傳輸的密碼學簽名

```
Queries
> paypal.com: type DNSKEY, class IN
Answers
  paypal.com: type DNSKEY, class IN
    Name: paypal.com
    Type: DNSKEY (48)
    Class: IN (0x0001)
    Time to live: 600
    Data length: 136
  > Flags: 0x0100
    Protocol: 3
    Algorithm: RSA/SHA1 (5)
    [Key id: 11811]
    Public Key: 03010001cfffabfbc3aa84839f6fcf27dc2a0226ecade1e37...
  paypal.com: type DNSKEY, class IN
    Name: paypal.com
    Type: DNSKEY (48)
    Class: IN (0x0001)
    Time to live: 600
    Data length: 264
  > Flags: 0x0101
    Protocol: 3
    Algorithm: RSA/SHA1 (5)
    [Key id: 21037]
    Public Key: 03010001d56d982eb23906f4fb9313e5ecc2f4626c09bd74...
  paypal.com: type RRSIG, class IN
    Name: paypal.com
    Type: RRSIG (46)
    Class: IN (0x0001)
    Time to live: 600
    Data length: 286
    Type Covered: DNSKEY (48)
    Algorithm: RSA/SHA1 (5)
    Labels: 2
    Original TTL: 600 (10 minutes)
    Signature Expiration: Feb 9, 2019 11:12:19.000000000 中国标准时间
    Signature Inception: Jan 10, 2019 10:42:55.000000000 中国标准时间
    Key Tag: 21037
    Signer's name: paypal.com
    Signature: 6d0097319ae200e147c96a3b50cd779ea68e948219b65262...
  paypal.com: type RRSIG, class IN
    Name: paypal.com
    Type: RRSIG (46)
    Class: IN (0x0001)
    Time to live: 600
    Data length: 158
    Type Covered: DNSKEY (48)
    Algorithm: RSA/SHA1 (5)
    Labels: 2
    Original TTL: 600 (10 minutes)
    Signature Expiration: Feb 9, 2019 11:12:19.000000000 中国标准时间
    Signature Inception: Jan 10, 2019 10:42:55.000000000 中国标准时间
    Key Tag: 11811
    Signer's name: paypal.com
    Signature: 6d00b10efa38607c5d7060d9d3e8e7a7df40b0c93d450a0...
```



通過非對稱加密驗證身份--DNSSEC

DNSSEC請求及驗證過程

RRSIG (Resource Record Signature)

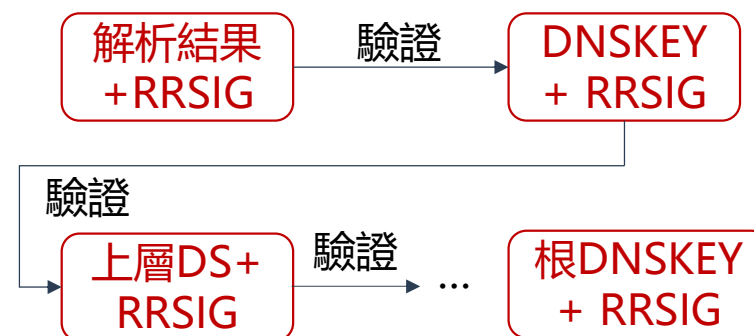
資源記錄簽名

DNSKEY (DNS Public Key)

公鑰記錄

DS (Delegation Signer)

DNSKEY的散列值，DS記錄存儲在上級域名服務器，用于建立信任鏈

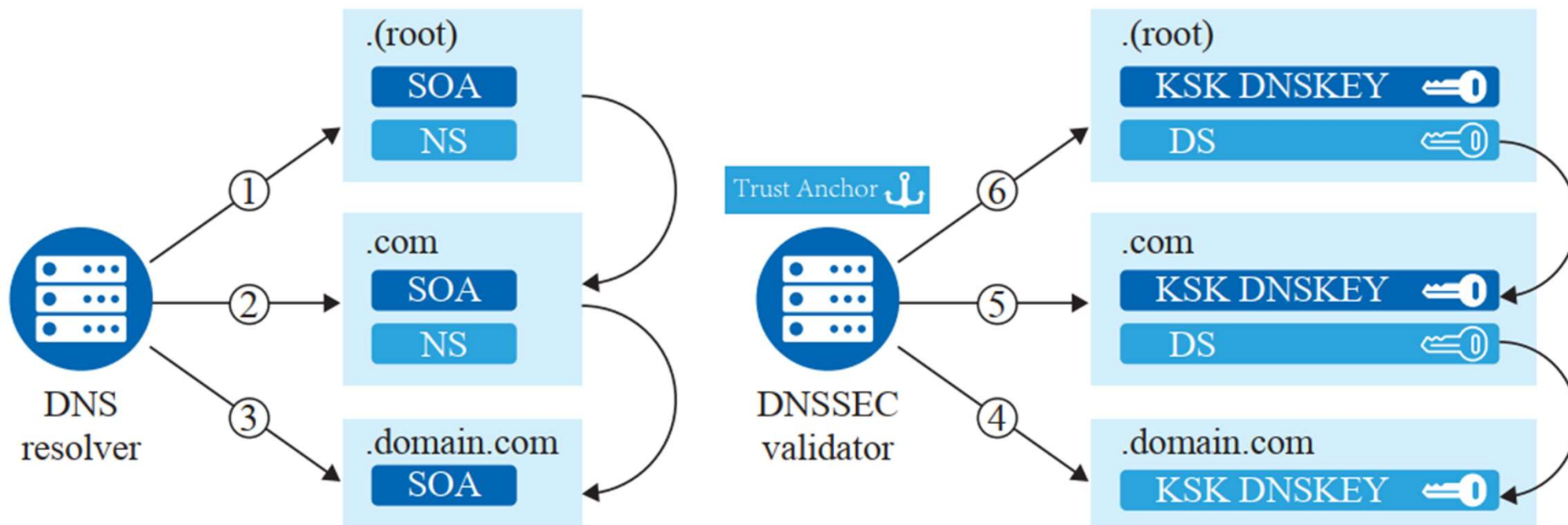


解析結果通過簽名（RRSIG）驗證，RRSIG通過公鑰（DNSKEY）驗證，公鑰通過上級公鑰散列（DS）及簽名驗證



通過非對稱加密驗證身份--DNSSEC

DNSSEC請求及驗證過程





通過非對稱加密驗證身份—DNSSEC的不足

可部署性

經濟因素制約其部署，大量簽名和驗證帶來嚴重的負載，影響效率，驗證能力取決于遞歸服務器以及客戶端是否對數字簽名記錄做校驗

設計能力

離綫存儲與頻繁使用密鑰，私鑰的安全無法保證；沒有提供機密性和一致性檢驗，無法抵禦重放攻擊；只提供單向認證，沒有對客戶的認證，不能解決緩存中毒；沒有提供DoS防護

引入錯誤

引入了新的實現和配置錯誤



DNS-over-TLS (DoT)



可部署性

在DNSSEC被廣泛接受之前（全球頂級域DNSSEC部署已經超過93%），需要找到其它解決方案有效阻止DNS攻擊造成破壞

信任鏈

DNSSEC用DNS區域層次結構提供信任鏈，TLS協議依賴公鑰基礎設施（PKI），包括證書授權中心（CA）

數據封裝

DNS-over-TLS 協議直接使用傳輸層安全協議對數據執行加密操作，保證了域名協議交互中信息的完整性與機密性



DNS-over-HTTPS (DoH)

數據封裝

DNS-over-HTTPS (DoH) 協議與現有域名系統不兼容，采用HTTPS 信道傳輸域名協議數據

DoH協議流量傳輸路徑

客戶端 -> DoH服務器 -> DNS服務器 -> DoH服務器 -> 客戶端

通用性

☒ 使用 SOCKS v5 时代理 DNS 查询

☒ 启用基于 HTTPS 的 DNS

☒ 使用默认值 (<https://mozilla.cloudflare-dns.com/dns-query>)

☐ 自定义

帮助 取消 确定

部分瀏覽器或操作系統直接支持DoH



基于系统管理

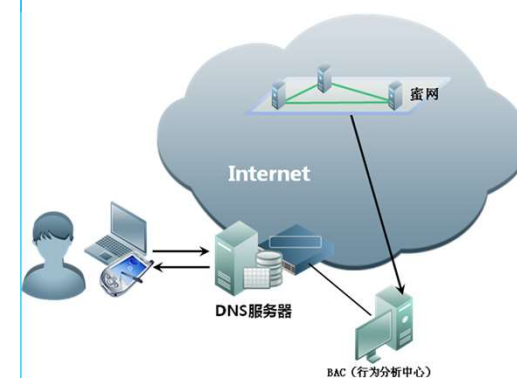


規範配置過程

1. 規範并梳理DNS配置過程中出現的漏洞

降低攻擊影響

1. 限制用戶在短時間內發起大量DNS查詢
2. 增加端口猜測難度，如用于查詢的UDP端口不再是默認的53，而在UDP端口範圍內隨機選擇（排除預留端口）
3. 分布式部署、惡意流量過濾等方案



蜜網和DNS防護系統聯合實現BotNet
檢測及惡意流量過濾



基于系统管理

嚴格檢查 (如Bailiwick)

- 附加區記錄和問題區問題不在同一域管轄，則不會采信，防範惡意權威DNS虛假記錄污染緩存
- 比如，請求www.foo.com時，應答包裹出現關於www.bar.com的記錄，根據bailiwick檢查規則，不會接受此A記錄

問題區:

www.foo.com A

權威區:

foo.com NS ns1.foo.com

附加區:

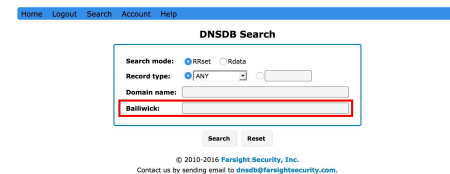
ns1.foo.com A 2.3.4.5

www.bar.com A 6.6.6.6

不采信

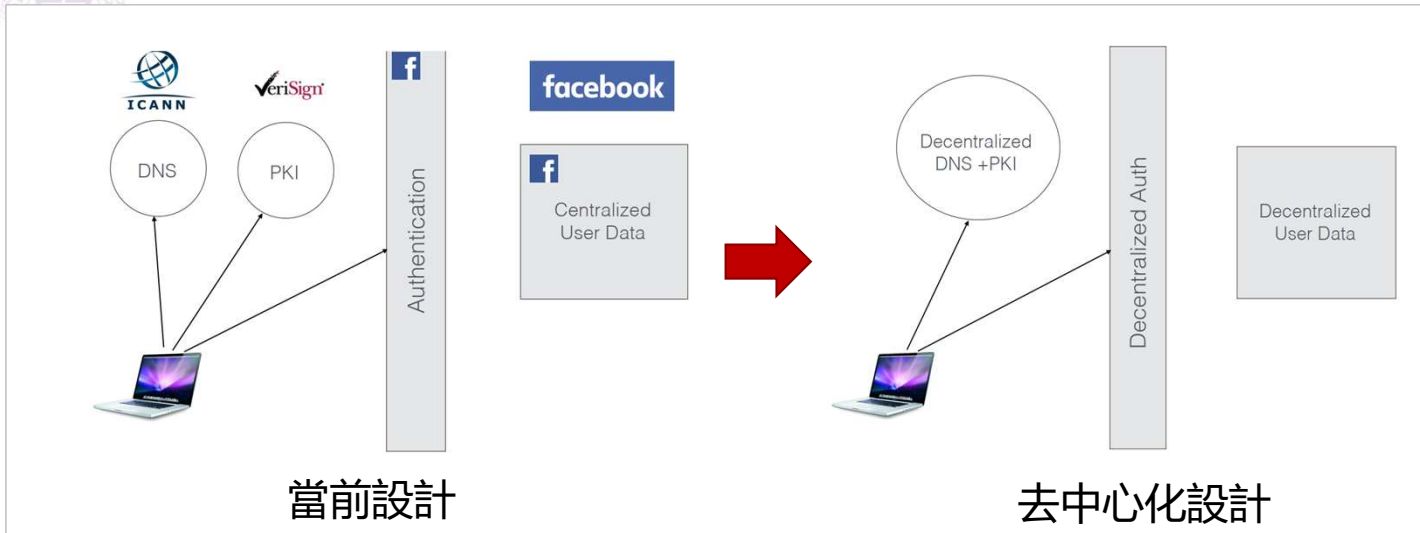


DNSDB提供
bailiwick檢查接口





新型架構設計-Blockstack



数据层	存储用户加密后的数据
对等网络层	存储数据资源的路由信息
虚拟链层	将数据提取出来呈现给上层用户
区块链层	记录用户操作并达成共识

Blockstack 旨在建立一個去中心化的域名系統及公鑰基礎設施

底層採用區塊鏈搭建，通過將域名哈希值以交易形式存儲在區塊鏈，以分布式方式避免篡改，提供可靠DNS服務



第五節 總結和展望





總結

熟悉了DNS的演進歷史、域名結構、區域形式、使用原理及基本解析過程，思考了DNS潛在的安全問題，學習了常見的DNS攻擊技術和防禦手段





展望

